Zero Trust Architecture for Enterprise Security

Naviotech Solution Pvt Ltd — Cyber Security Internship Minor Project 2 Submitted by:
Ayush Singh

1. Introduction

Traditional network security relies on a strong perimeter, trusting anything already inside the network. This model breaks down once a single device or credential is compromised, since an attacker who gets past the perimeter can often move freely. Zero Trust replaces this with a simple principle: **never trust, always verify** — every request is authenticated and authorized, regardless of where it originates.

1.1 Objectives

- Explore the concept of Zero Trust and how it applies to corporate environments
- Define authentication models, including Multi-Factor Authentication (MFA) and Role-Based Access Control (RBAC)
- Design a Zero Trust framework covering identity verification, micro-segmentation, and encryption
- Simulate an enterprise environment using virtualization tools
- Implement and test access control policies against simulated threats

2. Zero Trust Principles

Principle	Description
Verify explicitly	Authenticate and authorize based on all available signals (identity, device, location) every time, not just at initial login
Least privilege access	Grant users only the access they need, for only as long as they need it
Assume breach	Design as though an attacker is already inside; limit what any single compromised account or device can reach

These principles replace the older "trusted internal network" assumption with continuous verification at every access point.

3. Authentication Models

3.1 Multi-Factor Authentication (MFA)

MFA requires at least two independent proofs of identity before granting access:

Factor type	Example
Something you know	Password or PIN
Something you have	Authenticator app, hardware token
Something you are	Fingerprint, face recognition

Even if a password is stolen through phishing, MFA prevents the attacker from completing login without the second factor.

3.2 Role-Based Access Control (RBAC)

RBAC assigns permissions based on job role rather than per individual, keeping access predictable and auditable:

Role	Example Access
Employee	Email, shared drives, internal tools
Manager	Employee access + team reports, approval workflows
IT Administrator	System configuration, user account management
Finance	Accounting software, payment systems (restricted to Finance only)

Combining MFA (proving who you are) with RBAC (defining what you can access) forms the core of the authentication layer in this framework.

4. Zero Trust Framework Design

The framework is built around three layers:

4.1 Identity Verification

- Every user and device is authenticated before any access is granted
- MFA enforced for all accounts, especially privileged ones
- Continuous session validation, not just at login

4.2 Micro-Segmentation

- The network is divided into small, isolated zones (e.g. Finance, HR, Development, Guest) instead of one flat network
- A compromised device in one zone cannot directly reach resources in another
- Access between zones requires explicit policy approval

4.3 Encryption

- All traffic between zones and services is encrypted in transit (TLS)
- Sensitive data is encrypted at rest
- Certificates and keys are centrally managed and rotated regularly

5. Simulated Enterprise Environment

To test the framework, a small enterprise network was simulated using **VMware** with multiple virtual machines representing different network zones:

VM	Role	Zone
VM1	Domain controller / Identity provider	Core Identity
VM2	Employee workstation	Employee Zone
VM3	Finance application server	Finance Zone (isolated)
VM4	Guest device	Guest Zone (isolated)

Each zone was placed on a separate virtual network segment, with firewall rules permitting only explicitly approved traffic between them — for example, the Employee Zone can reach the Identity provider, but the Guest Zone cannot reach the Finance Zone under any circumstance.

6. Access Control Implementation

Using an Identity & Access Management (IAM) approach, policies were implemented as follows:

Policy	Rule
Default deny	All traffic blocked unless explicitly allowed
MFA enforcement	Required for all logins to Finance and Admin systems
Role-based routing	Finance VM only accepts connections from accounts tagged "Finance" role
Guest isolation	Guest Zone has internet access only, no access to internal zones
Session timeout	Idle sessions on privileged accounts expire after 15 minutes

7. Security Testing

The framework was tested against two simulated threat scenarios:

Scenario A — Compromised guest device: A test device in the Guest Zone attempted to reach the Finance VM. Result: blocked by micro-segmentation, confirming guest isolation worked as intended.

Scenario B — Stolen employee password: A login attempt was made to the Finance system using a valid employee password but without the second MFA factor. Result: access denied, confirming MFA prevented escalation from a single compromised credential.

Both tests confirmed that even with one control bypassed (network position in Scenario A, a password in Scenario B), the remaining layers of the framework still prevented unauthorized access — demonstrating the defense-in-depth value of combining segmentation with strong authentication.

8. Results and Improvements

Findings:

- Micro-segmentation successfully contained simulated lateral movement attempts
- MFA prevented access even when a valid password was supplied
- Default-deny policies meant any unplanned connection attempt failed safely, rather than being accidentally permitted

Suggested improvements for a production deployment:

- Add continuous device-health checks (e.g. confirming security patches are current) as an additional condition for access, not just identity
- Introduce centralized logging and alerting across all zones for faster incident detection
- Periodically review and tighten RBAC role definitions as team structures change

9. Conclusion

This project designed and tested a Zero Trust architecture for enterprise security, combining identity verification, micro-segmentation, and encryption with MFA and RBAC as its authentication foundation. Simulated attack scenarios confirmed that the framework successfully contained a compromised device and blocked unauthorized

access even when a valid password was exposed, demonstrating that Zero Trust's "never trust, always verify" principle provides meaningfully stronger protection than a traditional perimeter-based model.